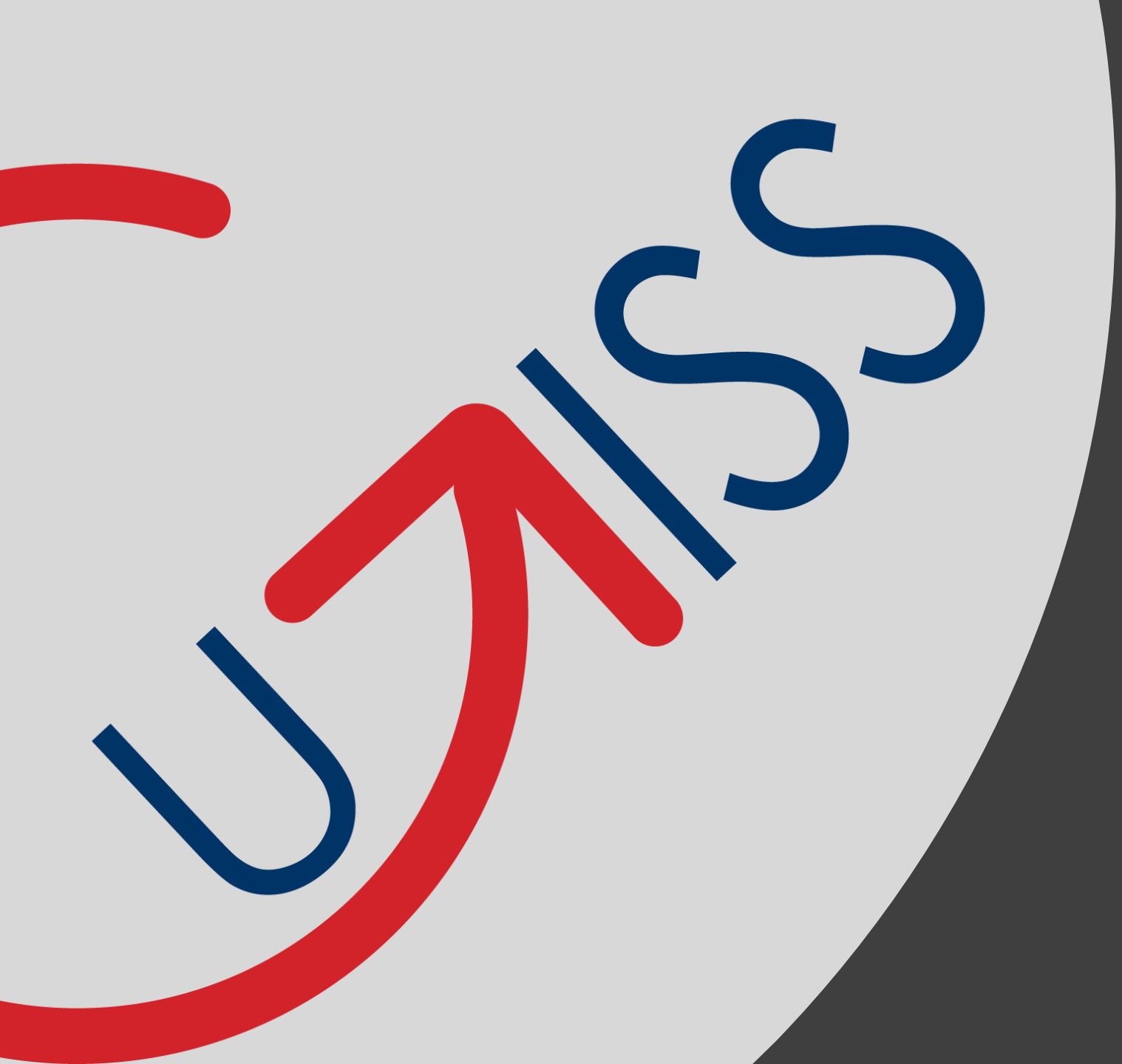


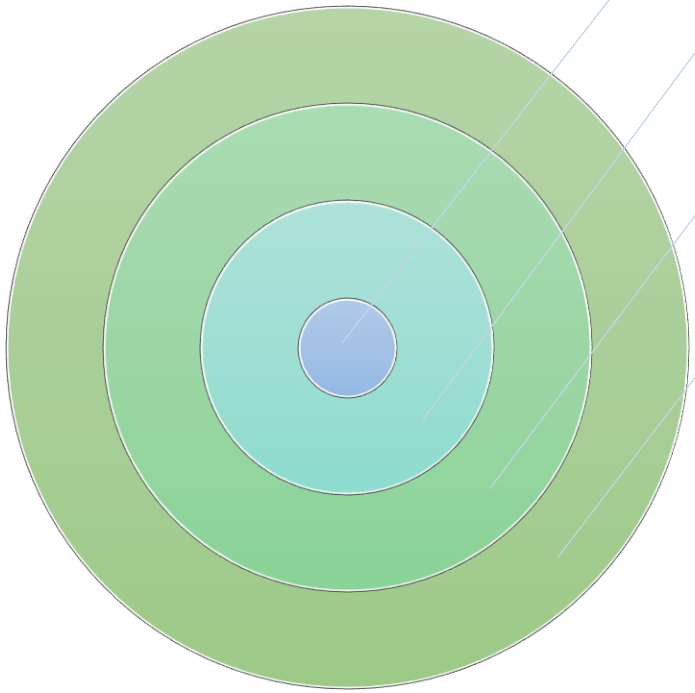
SQL Server Back to Basics: Sicurezza

Gianluca Hotz

Chi sono?

- Gianluca Hotz | @glhotz | ghotz@ugiss.org
- Consulente indipendente
  - 20+ anni su SQL Server (dalla 4.21 nel 1996)
  - Modellazione e sviluppo database, dimensionamento e amministrazione database server, aggiornamenti e migrazioni, performance tuning
- Community
  - 20+ anni Microsoft MVP SQL Server/Data Platform (dal 1998)
  - VMware Experts SQL Server
  - Fondatore e presidente UGISS (PASS Chapter)
  - Co-organizzatore DAMAG Meetup Community

Security Layering



Information Protection

- **Transport Layer Security (encryption in transit)**
- **Transparent Data Encryption (encryption at rest)**
- **Cell-Level Encryption (encryption at rest)**
- **Always Encrypted (encryption at rest and in transit)**
- **Dynamic Data Masking**

Threat Protection

- **SQL Auditing**
- **Advanced Threat Protection**

Access Management

- **Encrypted Authentication**
- **Authorization (Permissions, Row-Level Security)**

Network Security

- **Physical Firewall**
- **Service Firewall/Virtual Network Firewall**

https://docs.microsoft.com/en-us/azure/azure-sql/database/security-overview#information-protection-and-encryption

Livello di autenticazione

- Server login
  - Controllo degli accessi e permessi a livello di istanza
- Database User
  - Controllo degli accessi e permessi a livello di singolo database
- Ambiti riconducibili a livelli server e/o database
  - SQL Server Replication, SQL Server Agent Jobs
- Impersonificazione e funzionalità specifiche
  - Database Mirroring, Availability Groups
  - «Extensibility Framework»
  - Identità per Linked Server, Polybase
  - «Bulk Insert» da «Azure Blob Storage»

Modalità di autenticazione

- Nativa SQL Server
  - Utente e hash password mantenuti in SQL Server
- Integrata con Active Directory
  - Utilizza protocollo NTLM o Kerberos
  - Supporto Azure Active Directory
  - Supporto Active Directory Universal Authentication
    - Multi-factor Authentication (es. via telefono)
    - Supportata solo con SSMS a partire dalla versione 17+

Autorizzazioni

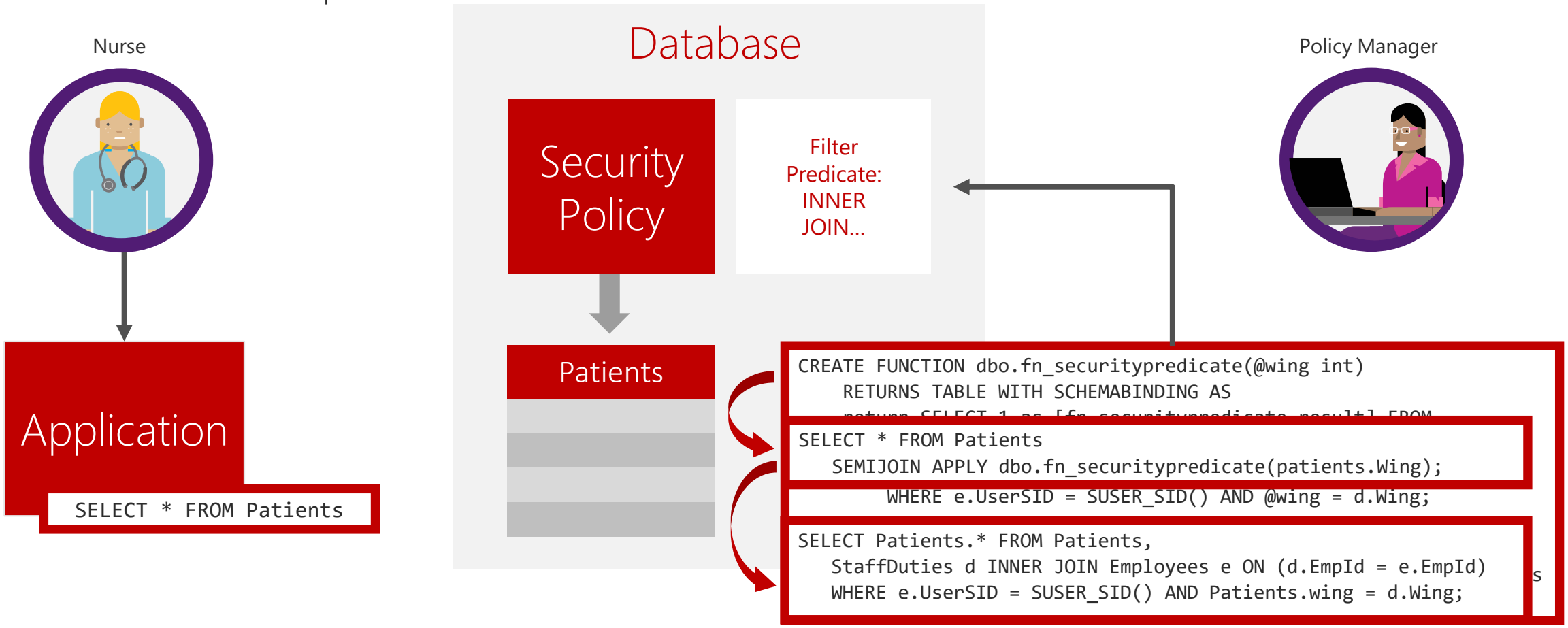
- Permessi granulari
  - GRANT cosa può fare ON su che oggetto TO chi
  - Ereditarietà gerarchia di oggetti
  - Assegnazione (GRANT), negazione (DENY), revocare (REVOKE)
  - Row Level Security
- Ruoli a livello di server e database
  - Es. sysadmin, dbcreator, db_datareader, db_datawriter
  - Specifici per alcune funzionalità (database msdb)
- Principio guida: minor privilegio!
  - Possibile elevare temporaneamente
    - Impersonation
    - Stored Procedure (in generale moduli T-SQL firmati)

Demo

- Autenticazione
- Autorizzazioni e permessi

«Row-Level Security»

Due
Il Security Policy in esecuzione di data per tutte le query di sicurezza. T-SQL, vincolando il predicato alla tabelle dei pazienti.



DEMO

- Row Level Security

Row-Level Security & Multi Tenancy

- Vincola accesso ai «tenant» quando «shard» condividono le stesse tabelle
- Assumendo esistenza colonna che identifica il «tenant»

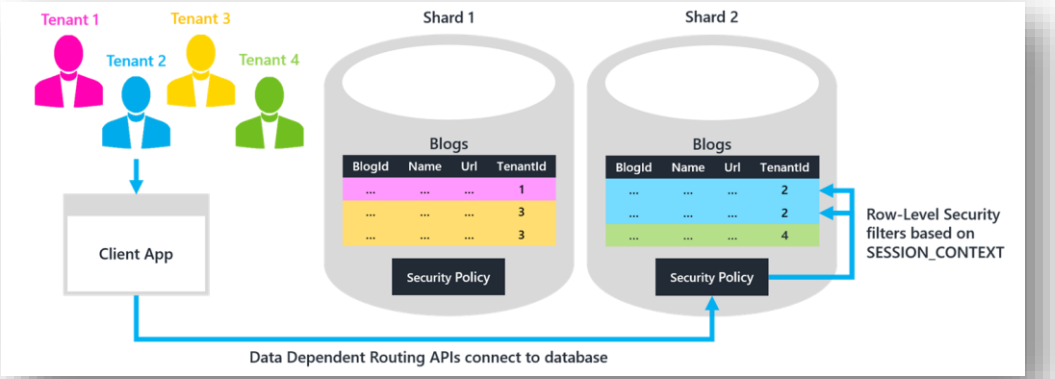


Image source: https://docs.microsoft.com/en-us/azure/sql-database/sql-database-elastic-tools-multi-tenant-row-level-security

Q&A

ghotz@ugiss.org

Q&A